

Deccan Speciality Chemicals, Site OT-03

How one workstation, one password and three configuration writes took three of the four protection layers off an operating chemical plant

EVENT	Reactor pressure relief valve lift, R-201, 04:41 on 3 April 2027
PLANT	Continuous agrochemical intermediate plant, Gujarat
SCOPE	Cyber-physical incident review, with a runnable mock of the environment and a full kill chain
PREPARED FOR	Site leadership, Process Safety, Control and Instrumentation, Corporate IT
STATUS	For review. Attribution remains open.

This document contains a working prototype of the plant, a categorisation of all thirty-two investigation findings, and a step-by-step reconstruction of the intrusion. Everything marked MOCK is fictional and built for this analysis.

Contents

How to read this report	2
Part 1 - Executive summary	4
Part 2 - The plant, and how it is protected	6
Part 3 - The prototype	9
Part 4 - The findings, sorted	12
Part 5 - What happened	18
Part 6 - Why it happened	21
Part 7 - The kill chain	24
Part 8 - Reproducing it on the prototype	28
Part 9 - What we cannot know, and why	31
Part 10 - What it cost, and what it put at risk	33
Part 11 - What to do, in order	34
Appendix A - The finding register in full	36
Appendix B - Lab artefacts	38
Appendix C - Re-running the analysis	40
Appendix D - Basis, limits and provenance	41

The two figures that carry the argument fastest are Figure 1, the architecture before and after 2021, and Figure 4, the pressure trace the historian recorded on the night.

How to read this report

This report does three things, in this order.

1. It explains the plant and the digital architecture it runs on, so that the rest of the document makes sense without an ICS background.
2. It sorts the thirty-two investigation findings into what actually caused the incident, what enabled it, what only looked relevant, and what was pure noise. Several findings that were given equal weight in the first pass turn out to carry no weight at all.
3. It walks through the intrusion minute by minute, using a working mock of the plant that was built for this analysis. Every technical claim in the kill chain is reproduced by running that mock, and the raw output sits in Appendix B.

One thing up front, because it shapes everything that follows. The relief valve lifting was the system working, not failing. The failure happened earlier, quietly, in three configuration writes and in an engineering decision made in 2021 that nobody in Process Safety was asked to look at.

Categorisation notation

Every finding in Part 4 carries one tag. The tags are the vocabulary the rest of the report uses.

Tag	Category	What it means
[CORE]	Attack chain	Part of what actually happened. Remove it and the incident does not occur, or cannot be understood.
[ENABLER]	Structural enabler	A condition that made the attack possible or invisible. Not itself an action; a weakness sitting in the architecture or the configuration.
[GOV]	Governance and assurance failure	A failure of process, review or oversight that allowed the enabler to survive, sometimes for years.
[SUSPICIOUS]	Suspicious, not proven	Consistent with deliberate activity and worth chasing, but the evidence does not close it.
[MASK]	Looks reassuring, proves nothing	True statements that were read as evidence of safety and were not. These are the most dangerous findings in the set, because they stopped people looking.
[GAP]	Detection or evidence gap	Something that was not watched, not recorded, or not kept long enough to answer a question the investigation later needed answered.
[NOISE]	Unrelated to the incident	Dramatic, easy to chase, and irrelevant. Included so that nobody spends the next month on it.

Table 0.1 - Finding categories used in this report

Terms used, in plain language

BPCS	Basic process control system. The ordinary control system that runs the plant day to day.
SIS	Safety instrumented system. The separate system whose only job is to put the plant into a safe state if the control system fails.
SIL 2	Safety integrity level 2. A measure of how reliably a safety function is expected to perform.
Override	A maintenance feature that makes a safety sensor look healthy while it is being worked on. The safety function cannot act while it is in place.
Suppression	Hiding an alarm from the operator, usually during maintenance, so the panel is not flooded with expected alarms.
PRV	Pressure relief valve. A spring-loaded mechanical valve. No electronics, no network, no software.
Independent protection layer	A layer that reduces risk and cannot be taken out at the same time as the others. The whole concept depends on that word.
MoC	Management of change. The process that is supposed to catch the consequences of a change before it is made.
VEL/1	The fictional vendor engineering protocol used in the mock. Represents the real proprietary protocol Deccan's safety controller speaks, which carries no authentication.

Part 1 - Executive summary

At 04:41 on 3 April 2027 the pressure relief valve on reactor R-201 lifted. It discharged to the scrubber for about ninety-six seconds and reseated. Nothing was released to atmosphere. Nobody was hurt. Throughput stopped for eleven hours. On the face of it, a relief valve doing exactly what a relief valve is for.

The investigation that opened that morning found something worse than a process upset. The panel operator had watched the reactor pressure climb for about nine minutes, with no alarm, and had started reducing feed by hand because he happened to notice the trend plot. The safety instrumented system, rated SIL 2 and proof tested six weeks earlier, did not trip. The historian shows the feed valve never moved, which is precisely the failure of the layer that was supposed to close it.

Three of the site's four protection layers were already out of action before the hazard existed. The order matters:

- At 23:52 on 2 April, a maintenance override was placed on the safety controller's reactor pressure input. It had no expiry date and nothing expires it. The SIL 2 trip could not see the pressure for the rest of the night.
- At 23:58, the reactor high pressure alarm was suppressed. The suppression list is not drawn on the operator's default view, so nobody was told.
- At 02:09 on 3 April, someone signed in to engineering workstation ENG-DCS-01 under the corporate account of a Control and Instrumentation engineer who was not at the site and was not working.
- At 02:14, the coolant flow controller was reconfigured from that workstation so its output tracked zero whatever the set point said. Cooling stopped. The set point stayed at 62 per cent, so nothing on the operator's screen looked wrong and the journal records no operating action at all.

Two hours and eighteen minutes later, the consequence arrived. Pressure rose, no alarm was presented, the trip did not fire, the feed valve stayed where it was, and the only thing left between the reactor and the atmosphere was a spring-loaded mechanical valve with no electronics in it. That valve is the reason this report is a near-miss study instead of an inquiry into a release close to a settlement of people living 1.8 kilometres from the fence.

Why it was possible

The origin of all of it is the 2021 convergence project. That project put the control system engineering software and the safety system configuration software on the same workstation, joined that workstation to the corporate Windows domain, put both sets of controllers on the same physical network segment behind a VLAN, and had the same nine engineers use the same corporate accounts for both. It was recorded as an information technology change. Its risk assessment covers licence compliance, vendor support and workstation performance. Process Safety is not recorded anywhere in it.

The site safety report rests on four protection layers which the quantitative risk assessment multiplies together. That arithmetic only holds if the layers fail independently. They stopped being independent in 2021. The report has been reviewed and re-confirmed every year since, and not one of those reviews mentions the project that invalidated its central assumption.

What the attacker actually did

Nothing clever. No malware, no exploit, no zero day. Corporate endpoint detection has a clean sheet on ENG-DCS-01 across a full year of alert history, and the investigators found no unexpected executable on the workstation, because there was nothing there to find. Every action in the intrusion used a vendor tool and a valid account. The safety engineering protocol has no authentication at all; the only gate is a

configuration-mode password that ships in the vendor's installation guide as a site-wide value and is identical on every installation of that software build. Deccan never changed it.

Three writes. One at 23:52, one at 23:58, one at 02:14. That is the whole attack.

What is still open

The technical reconstruction is solid: we can say what happened, when, and through which path. Three things we cannot say.

- Who did it. The sign-in at 02:09 is under an account whose owner was demonstrably elsewhere, which proves the account was used by someone else, but not by whom.
- When it started. The safety controller's event log is a 5,000 event rolling buffer and reaches back only to 9 January 2027. Anything before that has been overwritten by the controller's own housekeeping.
- Whether this was the first time. For the same reason, and this one may never be answerable. The log that would say so has already been recycled.

The single sentence that matters: the question 'can one person, or one stolen password, affect more than one protection layer?' has no recorded answer anywhere at Deccan, and the answer turned out to be yes.

Part 2 - The plant, and how it is protected

The process

Site OT-03 runs a continuous exothermic reaction in a pressurised reactor. The hazard basis is straightforward and unpleasant: if cooling is lost or feed is not controlled, the reaction runs away, pressure climbs, and the credible worst case is a loss of containment releasing a toxic and flammable inventory. There is a residential settlement 1.8 kilometres from the site boundary. Four hundred and twenty people work at the plant, which runs continuously and shuts down for a planned turnaround every eighteen months.

Process Safety at Deccan is six engineers, independent of Operations, reporting to the Site Director, with authority to stop the plant. Control and Instrumentation is nine engineers. IT is twelve people in Ahmedabad covering three sites. There is no OT security function and no person at the site whose security remit extends to the plant.

The four protection layers

The site safety report identifies four independent protection layers against reactor overpressure, and credits each with a risk reduction factor. The quantitative risk assessment multiplies those factors to arrive at the residual risk it submits. That multiplication is valid only if the layers fail independently. Everything in this incident follows from that sentence.

Layer	What it is	How it acts	Set point
1	Basic process control system	Modulates coolant flow and feed rate to hold the reactor inside its normal envelope	normal band 7.3 to 8.3 bar
2	Alarms to the panel operator	Presents a high pressure alarm on the operator's screen, requiring him to act	9.5 bar
3	Safety instrumented system, SIL 2	Closes the feed valve and opens the emergency coolant valve with no operator involvement	10.5 bar
4	Pressure relief valve	A spring-loaded mechanical device, sized to pass the full reaction rate, discharging to a scrubber	12.0 bar

Table 2.1 - The four protection layers as the safety report describes them

Layer 4 is worth pausing on. It has no electronics, no network connection, no software and no credential. It cannot be reconfigured, overridden, suppressed or tricked. It is the only layer in the list that was structurally out of reach on the night, and it is the only one that performed.

Figure 2 - The site's four protection layers, and what was left of them at 04:41 on 3 April 2027

Layer 1 - Basic process control coolant flow controller (FIC-101)	defeated at 02:14 configuration write, gain 0.0, set point untouched	OUT
Layer 2 - Alarms to the operator R-201 reactor high pressure alarm	defeated at 23:58 alarm suppressed from ENG-DCS-01, not shown by default	OUT
Layer 3 - Safety instrumented system SIL 2 logic, trips at 10.5 bar	defeated at 23:52 maintenance override on the pressure input, no expiry	OUT
Layer 4 - Mechanical relief valve spring loaded, 12.0 bar, no electronics	worked at 04:41 lifted, discharged 98 seconds, reseated	OK

The quantitative risk assessment multiplies the risk reduction of these four layers. That multiplication is valid only if they fail independently. Three of the four were reachable from one account on one workstation.

Figure 2 - The four layers, and their state at 04:41 on 3 April 2027.

The control system and the safety system

The control system is a distributed control system from one vendor, with operator stations in the control room, controllers in field cabinets, and an engineering station used to modify control logic and displays. The safety instrumented system is a separate safety controller from the same vendor, with its own logic solver, its own sensors and its own final elements, engineered using the vendor's safety configuration software.

The 2021 convergence project

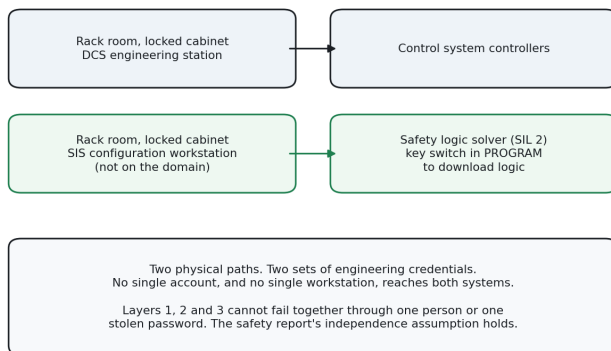
Before 2021 the safety instrumented system was engineered from a dedicated workstation in a locked cabinet in the rack room, and the control system from a separate station in the control room. In 2021 the site ran a project to consolidate engineering workstations, reduce licence cost and simplify vendor support. What it produced:

- One workstation, ENG-DCS-01, hosting both the control system engineering software and the safety configuration software.
- That workstation joined to the corporate Windows domain, so IT can patch it and engineers can sign in with their corporate accounts.
- The safety controller and the control system controllers on the same physical network segment, separated by a VLAN.
- Both systems engineered by the same nine Control and Instrumentation engineers using their corporate domain accounts.

The management of change record exists and is complete. It is categorised as an information technology change. Its risk assessment addresses licence compliance, vendor support and workstation performance. It does not reference the site safety report, and Process Safety is not recorded as a reviewer or approver. In its own terms, the project did what it said it would do, cheaply and without incident, and nobody looked at it from a process safety angle because nobody was asked to.

Figure 1 - Deccan OT-03: how the safety system was engineered before and after the 2021 convergence project

Before 2021: two separate engineering paths



After 2021: one workstation, one account, both systems

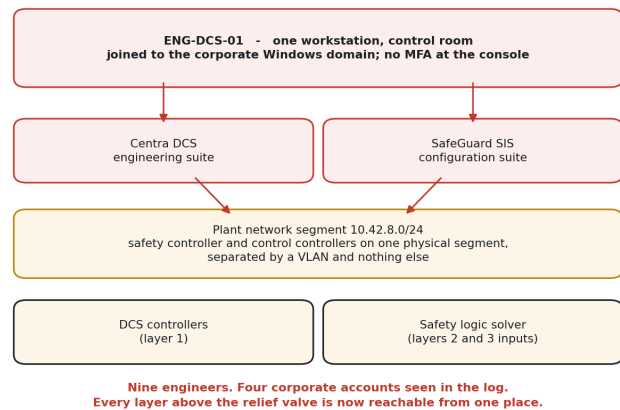


Figure 1 - The same plant engineered two ways. On the left, two paths and two sets of credentials. On the right, one workstation and one account reach everything above the relief valve.

How the safety system is engineered, and where it is soft

Three properties of the safety system matter to this incident, and all three are standard, documented, and defensible in isolation.

First, the protocol. The configuration software talks to the safety controller over the vendor's proprietary engineering protocol. That protocol carries no authentication. Authorisation is enforced by the software, which asks for a password to enter configuration mode. The password is a property of the software installation and is printed in the vendor's documentation as a site-wide value, identical on every installation of that software version. "Authorisation" on the layer meant to be the last line of automated defence rests on a string in a manual.

Second, the key switch. The safety controller has a physical key switch with positions RUN and PROGRAM. A logic download is refused in RUN. An override may be set in RUN. The key is held by the Control and Instrumentation lead. This control does exactly what it was designed to do, which is stop someone changing the safety logic. It does not stop someone neutralising a sensor.

Third, maintenance overrides. Individual safety function inputs may be overridden from the configuration software. There is no time limit and no automatic expiry. An active override is shown on a dedicated panel mounted on the rear wall of the control room, behind the operator's normal working position, and recorded in the controller's event log. Two indications, both passive, neither designed to demand attention.

The corporate estate it sits in

The domain holds 1,100 accounts across three sites. Passwords are twelve characters and must change every 180 days. Multi-factor authentication is enforced for remote access and is not enforced for interactive sign-in to domain-joined workstations on site. The IT service desk verifies a caller's identity for a password reset by asking for an employee number, which is printed on the site identity badge that people wear on their chests.

None of that is unusual, and all of it was written by people who had no reason to think about the fact that one of the workstations sitting behind those policies is a workstation that can defeat a SIL 2 safety function.

Part 3 - The prototype

A mock of the environment was built to go with this report. It exists for one reason: an incident like this is easy to describe and hard to believe. Running it removes the belief question. Every claim made later in the kill chain is reproduced by the mock, and the artefacts the mock produces are the artefacts the report quotes.

What it is

The prototype is a small Python package (no third-party dependencies, no network access beyond loopback) containing the pieces of the real environment that this incident touched, and nothing else:

Component	Stands for	Behaviour reproduced
SafeGuard SIS logic solver	The site's safety controller and the VEL/1 engineering protocol	No authentication; one shared vendor password; overrides settable in RUN with no expiry; logic downloads refused in RUN; 5,000 event rolling log
Centra DCS controller	The control system and its engineering interface	Loop configuration writes journalled against a corporate account; alarm suppression with a current-state-only list; no display of suppressed alarms by default
Reactor model	R-201 and the mechanical relief valve	Pressure held by cooling; a runaway when cooling is lost; the relief valve lifting at 12.0 bar, discharging and reseating
Historian	The 10-year, one-second process historian	Records values only. It cannot say who caused a value to change, which is why finding F1 describes behaviour and not an actor
Corporate estate	Domain, endpoint detection, firewall, service desk	180-day sign-in log, 30-day endpoint events, 365-day alert history that is empty because nothing was raised, 90-day firewall log, tickets verified by badge employee number
Maintenance override set	The 11 overrides covered by proof test records, and the 3 that are not	The event log ages the way a 5,000 event ring ages: by housekeeping traffic, not by calendar

Table 3.1 - What the prototype models, and what each piece stands for

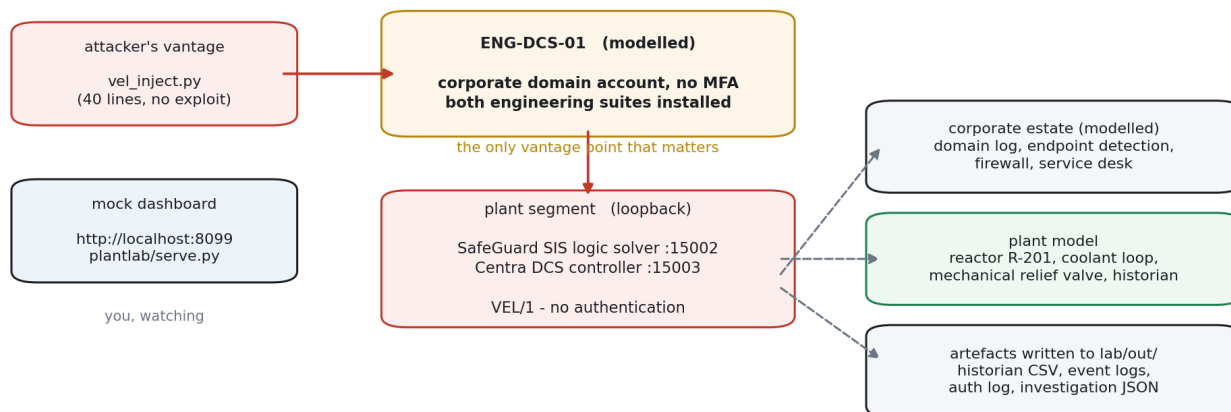
What it deliberately simplifies

Honesty about the limits of a model matters more than the model's polish. Five simplifications, and what each one costs:

- The protocol is JSON over TCP rather than a real binary vendor protocol. The point being demonstrated is the absence of authentication, not the byte layout.
- The reactor is a shape model, not chemical kinetics. It is fitted so the historian reproduces the trace the investigation described: normal pressure at 04:32, the 9.5 bar alarm set point crossed around 04:37, the 12.0 bar relief set pressure at 04:41. It is not a simulation anyone should use for engineering.
- The analyst's own tolerance is modelled explicitly. The 04:37 alarm crossing against the 04:41 lift comes out of the fitted constants, and the fitted constants exist to match the record, not to predict a real runaway.
- Operator reaction times are event-driven. The operator's manual feed change only reaches the valve after a dead time, which is how the record shows the feed valve holding its position throughout the rise. That dead time is a modelling device; what the record itself means is simply that whatever he did had not reached the valve by 04:41.
- Corporate history is generated from a seeded scenario rather than replayed from real logs, so the counts in finding F5 line up with the case study. Treat the shape as real and the timestamps as illustrative.

Layout

Figure 6 - The prototype as it runs: everything on one machine, nothing on a real network



There is no firewall object in the prototype, because in this incident the corporate-to-plant boundary was a log source, not a barrier. Everything runs on loopback. The vulnerabilities are deliberate: this is a teaching artefact, not something to expose to a network.

Figure 6 - The mock as it runs on one machine. The attacker's vantage point, the workstation, the plant segment and the two controllers are all that matter.

Running it

```
$ cd lab
$ python3 plantlab/serve.py           # the plant plus a live dashboard on :8099
$ python3 vel_inject.py recon         # what an attacker sees from the segment
$ python3 vel_inject.py inject        # the three writes, with the responses
$ python3 -c "from plantlab import flows; flows.run_all()" # the full replay
$ python3 make_diagrams.py            # redraw every figure in this report
```

The dashboard is the part worth playing with. It has a play button that runs the night in compressed time, and it has three buttons that fire the three writes by hand. Pressing those three buttons yourself, with auto-attack switched off, is the fastest way to understand this incident: you will do the whole attack in about four seconds, using one account, and nothing in the plant will object or notice.

The code, and where to look

Finding	File	What to read
F11, F12	plantlab/safety_controller.py	The auth command: one shared password, compared to a constant that is documented as being in the vendor guide
F13	plantlab/safety_controller.py	Logic download refused in RUN; override set accepted in RUN. Two lines, side by side.
F8, F10	plantlab/safety_controller.py	The override record has an expires field that is always None
F31	plantlab/stores.py	RingLog: pop from the front when the buffer is full, and the report of how many entries that has silently destroyed
F16	plantlab/stores.py	CurrentStateOnly: a class whose history() method returns an empty list by design
F3, F2	plantlab/control_system.py	loop.configure journalling the corporate account; step_coolant_loop showing output = $sp * gain + bias$
F1	plantlab/process_model.py	The fitted runaway curve, with the feed valve deliberately left alone

Finding	File	What to read
F5, F27	plantlab/corporate.py	The seeded sign-in pattern and the service desk ticket whose verification is an employee number on a badge
the night	plantlab/flows.py	run_incident(): the order of the three writes is the order in the file
the analysis	plantlab/investigate.py	Five functions, one per evidence question, each reading the artefacts the incident actually left

Table 3.2 - Where each finding is implemented

Part 4 - The findings, sorted

Thirty-two findings were established. They are not equally important, and the team's first chronology lists them in the order they were established rather than the order in which they mattered. Sorting them is most of the analytical work.

Two warnings before the table.

- High drama is not a signal. The largest number in the whole case, 220,000 refused connections from 9,400 sources, is noise. The smallest, a single suppression event at 23:58 that exists only because the control system journal happened to log it, is one of the three actions that caused the incident.
- The reassuring findings are the dangerous ones. Three findings in this set are true, positive, and completely beside the point, and each of them reduced the likelihood that somebody would look in the right place.

4.1 The whole register, categorised

ID	Finding in one line	Category	Why it is in that category
F1	Historian: pressure rose from normal to relief set pressure between 04:32 and 04:41; coolant flow fell to zero; feed valve never moved	[CORE]	This is the physical incident. Coolant at zero with the feed valve holding position is the exact signature of a layer 1 defeat that layer 3 should have caught and did not.
F2	Coolant controller output fell to zero while its set point was unchanged, and the journal shows no operator action	[CORE]	Distinguishes a configuration change from an operating action. An operator turns a set point down; this was the controller's responsiveness that was removed.
F3	Journal: the coolant controller was reconfigured at 02:14 from ENG-DCS-01 under an engineer's corporate account	[CORE]	The action that created the hazard, with its time, host and account attached.
F4	The engineer named in F3 was not at the site and was not working	[CORE]	Turns F3 from an operational event into a security event. It proves the account was being used by somebody other than its owner. It does not say who.
F5	27 interactive sign-ins to ENG-DCS-01 across the window, four accounts, 21 between 01:00 and 05:00, only two with a call-out record	[SUSPICIOUS]	A genuine anomaly and the strongest behavioural clue in the set, but it is a pattern, not proof: nineteen unaccounted night sessions could still, individually, have innocent explanations.
F6	ENG-DCS-01 is domain-joined and hosts both engineering suites; engineers use corporate accounts	[ENABLER]	The convergence in one sentence. It is what makes F4 usable and what makes the corporate identity system relevant to the safety system.
F7	Endpoint detection covers ENG-DCS-01, raised no alert in a 365 day history, and found no malware	[MASK]	True, and it says only that no malicious file was present. The incident needed no malicious file, so a clean endpoint is what successful use of valid credentials looks like.
F8	SIS log: a maintenance override was set on the reactor high pressure input at 23:52 and never cleared	[CORE]	The defeat of layer 3, and the reason the SIL 2 function could not see the pressure.
F9	The override indication panel is on the rear wall; the operator recorded that he did not observe it	[ENABLER]	The only physical indication of a live override was placed where the person who needed it never looked.
F10	No time limit and no automatic expiry on overrides; of 14 override events, 11 match proof test records and 3 do not	[ENABLER]	The absence of expiry is why the override was still live at 04:41. The three unmatched events are a separate, weaker signal and are discussed under 4.3.

ID	Finding in one line	Category	Why it is in that category
F11	The engineering protocol carries no authentication; authorisation is enforced by the software	[ENABLER]	Removes authentication from the safety layer entirely. Anyone who can reach the controller on the network can act.
F12	The configuration password is a site-wide vendor-documented value, identical on every installation, unchanged at Deccan	[ENABLER]	Turns 'authorisation' into a published string. With F11, this is the entire access control model for the SIS.
F13	Key switch RUN/PROGRAM: downloads refused in RUN, overrides permitted in RUN	[ENABLER]	A control that protects the logic but leaves the sensors exposed. It also explains why nothing looked tampered with afterwards.
F14	No logic download in the retained window; the logic matches the proof-tested version	[MASK]	Reads as 'the safety system is untouched', and it is true. It also cleared the field of everyone hunting a logic bomb while an override sat unexamined in the same log.
F15	Proof test tested the function end to end, but requires overrides to be cleared first, by the engineer doing the test	[GOV]	The one recurring independent check of the SIS is structurally blind to a pre-existing override. It measures the wiring and skips the state.
F16	Journal: the reactor high pressure alarm was suppressed at 23:58 from ENG-DCS-01; the suppression list keeps current state only	[CORE]	The defeat of layer 2. The absence of suppression history is a detection gap layered on top of an attack step.
F17	Suppressed alarms appear on a list the operator may open, which is not displayed by default; he did not open it	[ENABLER]	A maintenance convention built for tidiness that becomes concealment when it is used with intent.
F18	The safety report credits four independent layers and multiplies their risk reduction	[GOV]	The assumption that was invalidated in 2021 and never revisited. It is the arithmetic the site relied on.
F19	The 2021 project's MoC is categorised as an IT change; its risk assessment covers licensing, support and performance; Process Safety did not review it	[GOV]	The moment the independence assumption stopped being true, without anyone qualified noticing.
F20	Before 2021 the two systems were engineered from separate, differently located workstations	[ENABLER]	Establishes that separation was the deliberate original design, and the 2021 project removed it. This is not a historic detail; it is the control that was given up.
F21	Since 2021 the safety controller and the control controllers share one physical segment, separated by VLAN	[ENABLER]	VLAN separation manages broadcast traffic and casual browsing. It is not a security boundary against someone already holding valid engineering credentials on the adjacent host.
F22	The safety report has been reviewed annually since 2021, each review confirming it remains valid, none referencing the project	[GOV]	Six confirmations of a document whose central assumption was no longer true. The reviews checked the paperwork, not the plant.
F23	The August 2026 regulatory inspection recorded the SIS as compliant and independently proof tested	[MASK]	Accurate on what it examined and silent on what it did not. It verified the tests were done, not that the layers were still independent.
F24	No network flow records are collected on the plant segment and no capability exists to collect them	[GAP]	The plant network is unwatched. Whether the safety protocol was ever spoken to by any host other than ENG-DCS-01 is unanswerable.
F25	The corporate-to-plant firewall log, 90 days, shows permitted connections from ENG-DCS-01 to the plant segment throughout	[NOISE]	This is what the firewall is supposed to see. An engineering workstation engineering. The log is evidence that logging works and evidence of nothing else.
F26	MFA is enforced for remote access and not for interactive sign-in on site; 1,100 domain accounts; 12 character, 180 day passwords	[ENABLER]	The identity control that exists everywhere except on the interfaces that can reach a safety function.

ID	Finding in one line	Category	Why it is in that category
F27	Service desk ticket of 11 December 2026: a password reset verified by employee number, printed on the site identity badge	[SUSPICIOUS]	A plausible initial access point, sitting eleven days before the access pattern in F5 begins. Not proven, and worth treating as unproven rather than as fact.
F28	220,000 refused connection attempts from 9,400 sources, 8 to 12 January; all refused and routine	[NOISE]	Internet background scanning that never reached anything involved. Its only value is as a decoy for the next review.
F29	The relief valve is mechanical, was certified in 2026, lifted at set pressure and reseated correctly	[CORE]	The reason this is a near miss. It also identifies, by elimination, which layer nothing in the intrusion could reach.
F30	Process Safety established within four hours that no alarm was presented and the SIS did not trip	[CORE]	Correct layer-failure reasoning, performed before anyone suspected a cyber dimension. It is what put the investigation onto the right track.
F31	The SIS event log holds 5,000 events and is overwritten; it reached back only to 9 January 2027 when read on 6 April	[GAP]	The evidence limit. Nobody can say what happened before January, or whether this had happened before. The retention mechanism also destroyed the evidence, which is worth knowing in itself.
F32	Deccan has no record of any assessment of whether one person or one account could affect more than one protection layer	[GOV]	The missing question. Not a missing control: a missing category of thought, which is why every other governance finding was possible.

Table 4.1 - All thirty-two findings with category, role and support

4.2 The findings that actually matter

Eight findings form the spine of the attack: F1, F2, F3, F4, F8, F16, F29 and F30. If you were told only these, you would know what happened.

The logic of the set is tight. F8, F16 and F3 are the three actions, in sequence, and F2 is what makes F3 legible as an action at all, because it separates a controller that was misconfigured from a controller that was commanded. F1 is the consequence in the physical record. F4 is what converts a plant event into an intrusion. F29 is the reason we are reading a report instead of an accident bulletin. F30 is the reasoning that found the thread.

Note what none of these eight findings is. None of them is a network log, an endpoint alert or a malware artefact. The entire attack chain is reconstructible from plant-side records and one corporate authentication log, because the attacker left nothing else behind. That is worth sitting with: the detection capability that mattered was a process historian, and it was being used as evidence after the fact rather than as a control.

4.3 The suspicious findings, and how far each can be taken

Two findings are suspected attack activity without proof. Both deserve attention; neither should be promoted to fact.

F5 - Twenty-seven sign-ins, twenty-one of them at night

Between 6 January and 3 April, the domain log records 27 interactive sign-ins to ENG-DCS-01 using the accounts of four Control and Instrumentation engineers. Twenty-one fall between 01:00 and 05:00. The engineers work day shift and are called out by telephone for night work, and call-out records exist for two of the twenty-one.

The distribution is the point. One night visit is a call-out. Nineteen unexplained night visits spread across four identities, on the one workstation in the estate that can reconfigure both the control system and the safety system, over nearly three months, is not a coincidence and is not what maintenance looks like. It reads as sustained, deliberate access shaped to resemble routine engineering.

What it does not do is identify anybody. Each individual sign-in is a valid credential at an unusual hour. Only the pattern is anomalous, and patterns do not appear in court. This finding requires the personnel investigation that sits outside the technical evidence.

There is a good argument that the pattern points away from a lone insider: it uses four accounts, which is more consistent with an external actor who obtained more than one credential than with one employee working late. That argument is suggestive and not conclusive, and the honest position is that attribution is open.

F10 - Three override events with no matching proof test record

Of fourteen override events in the retained window, eleven correspond to proof test records. Three do not. Two of the three sit inside the anomalous access window, on 11 January and 7 March, both on the same pressure input that was overridden on the night of the incident, both in the small hours, both from the same account that appears in the F5 pattern.

The reading is that these are rehearsals: occasions on which the mechanism was set and cleared, or set and left, without any operational reason recorded. That reading is probable, not certain, and the controller's rolling log makes it worse: the ring only reaches back to 9 January, so anything before that has been overwritten and a longer rehearsal history may exist without any way to recover it. The lab run reproduces the same constraint and shows the same figure, from the same cause.

F27 - The password reset, verified by a badge number

On 11 December 2026 a Control and Instrumentation engineer could not sign in to ENG-DCS-01 and his password was reset by the service desk, with the caller's identity verified by employee number, which is printed on the site identity badge.

This ticket is the best available candidate for the initial access point. It involves an account that later appears in the F5 pattern, it falls eleven days before the anomalous access window opens, and the verification method used is the weakest identity proofing anywhere in the estate. What it is not is proof. No log evidence connects this specific reset to any subsequent activity, and the engineer may genuinely have forgotten his password on a Friday. The finding belongs in the report because the process as designed would not have stopped an impersonation attempt, and because eleven days later somebody started signing in at two in the morning.

4.4 The findings that look serious and are not the incident

Two findings are genuine noise. A third is normally filed with them and should not be, which is why it gets its own section below.

F28 - The January scanning

Between 8 and 12 January the edge firewall refused 220,000 connection attempts from 9,400 source addresses. It is tempting, because the window overlaps the start of the access pattern in F5, and because 220,000 is a number that gets attention in briefing rooms.

It is background scanning. Every connection was refused at the internet edge. Nothing in the case study, in the retained logs, or in the prototype connects any of those sources to the corporate network, the plant segment, or ENG-DCS-01. The attack path in this incident did not touch an internet-facing service at all; it used a badge number, a help desk, a vendor password and a workstation on the control room floor. Chasing this is chasing a coincidence of dates.

F25 - The firewall log full of legitimate engineering traffic

Ninety days of permitted connections from ENG-DCS-01 into the plant segment. It is exactly what the host is for. It is also the reason this log cannot help: a log that records everything an engineering

workstation is supposed to do, on a segment with no flow records, cannot distinguish engineering from misuse. Expecting this log to have caught the incident is expecting a doorbell to report burglaries in a house where the burglar used the front door with a key.

4.5 Findings that looked reassuring and were not

This is the most important section in Part 4, because these three findings are the reason the incident was not found earlier, and would not be found earlier next time.

F7 - A clean endpoint

Corporate endpoint detection covers ENG-DCS-01, retains 30 days of events, and raised no alert on that asset at any point in a 365-day alert history. The investigation found no malware and no unexpected executable. All true.

There was nothing for it to catch. The intrusion used a signed vendor application and a valid corporate account to issue three writes. Endpoint detection is built to notice things that should not be on a machine. Nothing that should not have been on the machine was on the machine. Reading a clean endpoint as reassurance here is reading a smoke detector as evidence that nobody was using the kitchen.

F14 - No logic download, logic matches the proof test

The safety controller's event log shows no logic download in the retained window, and the logic on the controller matches the version recorded at the February proof test. This is genuinely good news: nothing about the safety function's logic was tampered with, and there is no logic bomb waiting in the controller.

It is also the finding most likely to misdirect an investigator. A review starting with 'the safety system did not act' will look for changed logic, find it clean, and conclude the safety system is not the place to look. The attack did not need to change the logic. An override makes the trip unreachable without touching a line of it, and the override sits in the same event log, a few entries away, being read at the same time by the same person.

F23 - The regulator's inspection, six months earlier

The August 2026 inspection examined the safety report and the proof test records and recorded the SIS as compliant and independently proof tested. Both statements were accurate about what was inspected.

The word doing the work is 'independently'. The inspection verified that proof tests had been performed, to procedure, and passed. It did not, and under current practice could not, examine whether the architecture still supported the independence the tests assumed. Paperwork compliance and architectural independence are different things, and this incident is the demonstration.

There is a question here for the regulator as well as for Deccan, and it is fair to put it in writing: if a site can be inspected, found compliant, and then have three of four protection layers removed by one account six months later, what in the current inspection method would have caught it?

4.6 The evidence gaps

Two findings limit what can ever be established, and a third limitation lives inside F16.

- F31, the safety controller's ring log. Five thousand events, overwritten, reaching back to 9 January 2027 when read on 6 April. The mechanism that destroyed the record is the controller's own housekeeping; the prototype reproduces this exactly, and the arithmetic works out at roughly eighty-seven days of coverage for the event rate involved. Before 9 January, nothing.
- F24, no network flow records on the plant segment, and no capability to collect them. We cannot show whether the safety protocol was ever spoken to from a host other than ENG-DCS-01, or whether any other device on that segment was involved.

- Inside F16, no history of alarm suppression. The single suppression event on the night is known only because the control system journal happened to record the suppression action itself. The suppression feature is not designed to be auditable, so we cannot say whether suppression was tried on other occasions.

None of these three stops the reconstruction. Each of them stops a different question, and all three would have been caught by cheap, well-understood measures: keep more events, turn on flow logging, log the suppression list.

Part 5 - What happened

This part is the narrative. It is written in the order events happened, not the order the investigation found them, because the order is the attack.

Figure 3 - The night of 2-3 April 2027: protective layers are removed before the disturbance is created

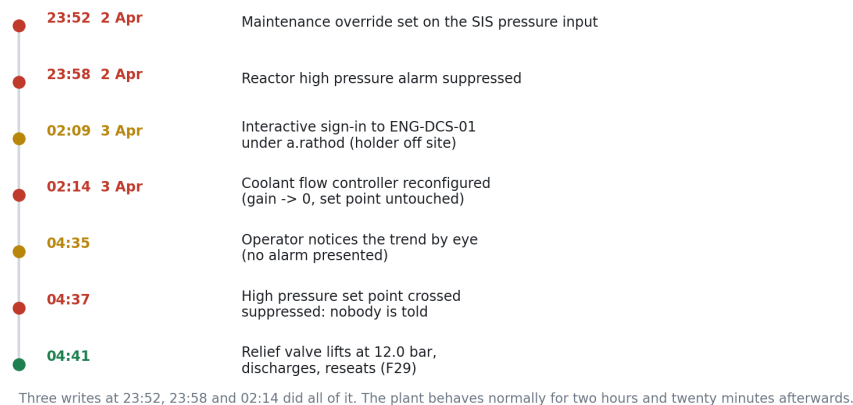


Figure 3 - The night of 2-3 April 2027. Everything that mattered happened before the reactor began to warm up.

23:52, 2 April: the safety layer is taken out of reach

A maintenance override is set on the reactor high pressure input, PIT-104. The override is set from ENG-DCS-01, and the controller accepts it while its key switch is in RUN (F13). The controller records the event in its log with no expiry attached (F8).

What an override actually does is worth being precise about, because it is easy to read as a broken safety system and it is not. The trip logic is intact, armed and ready. The override makes the pressure input present itself as healthy whatever is really happening in the vessel, so the trip condition is never met. The safety function is not defeated in the sense of being damaged. It is blinded, which is a different thing and a much quieter one.

The controller's own protocol required no credential to accept the write. The configuration software asked for the configuration-mode password, and the password is the one printed in the vendor's installation guide, unchanged since commissioning (F11, F12).

23:58, 2 April: the operator is not told

Six minutes later the reactor high pressure alarm is suppressed, again from ENG-DCS-01 (F16). Suppression is a legitimate plant feature. It exists so that an operator working through a known transient is not buried in repeat alarms. Suppressed alarms live on a list he may open, and the list is not displayed on his default view (F17). He did not open it, and nobody told him to.

There is one small mercy in the record here, and it is nearly not there at all. The control system journal logs the suppression action, because the suppression feature writes a journal entry. The suppression list itself keeps current state only and no history at all (F16). Without that journal entry, this step would exist only as an unexplained absence of something that never happened, which is close to invisible.

02:09, 3 April: somebody uses an account that is not theirs

The domain authentication log records an interactive sign-in to ENG-DCS-01 under the corporate account of a Control and Instrumentation engineer (F4). The engineer was not at the site and was not working. His account was being used by somebody else.

Nothing about this sign-in is unusual to the systems observing it. There is no multi-factor authentication on interactive sign-in to domain-joined workstations on site (F26), so a password is sufficient. The log entry looks like every other entry in the log. The only reason we know it was not the engineer is that a human being checked where that human being was.

02:14, 3 April: cooling stops, and nothing says so

The coolant flow controller, FIC-101, is reconfigured from ENG-DCS-01 under that account (F3). Two configuration parameters are changed. The controller's input gain is taken to zero and its bias is left at zero, which makes its output track $sp \times \text{gain} + \text{bias}$, that is, zero, for any set point in the range.

The set point is never touched. It stays at 62 per cent all night. The operator's screen shows a controller with a healthy set point and a live loop tag. The historian records a controller whose output has fallen to zero while its set point is unchanged and the control system journal records no operator action on it (F2). Those three facts together are the fingerprint of this attack step, and everything the initial investigation needed was already in the first two.

Cooling is now gone. The plant carries on looking normal, which is the point of doing it this way rather than by shutting a valve.

02:14 to 04:32: two hours and eighteen minutes of nothing

This is the part that is genuinely hard to accept when you first read the record. The reactor is being held at normal pressure by a cooling system whose output is zero, which cannot last, and for two hours and eighteen minutes nothing observable happens. There is no alarm, because the alarm is suppressed. There is no trip, because the trip is overridden. There is no process deviation to notice, because without cooling the vessel takes that long to begin to show the effect (F1).

The prototype reproduces this behaviour, and it is worth saying why this is not a modelling accident. An exothermic reaction with heat accumulating behind it has a take-off, and take-offs are fast and late. Two hours of nothing and then nine minutes of everything is what this class of hazard looks like. It is also exactly why the layered protection existed in the first place.

04:32 to 04:41: nine minutes, no alarm, no trip, no feed isolation

Figure 4 - What the process historian recorded, 03:40 to 04:50 on 3 April 2027 (from the lab run)

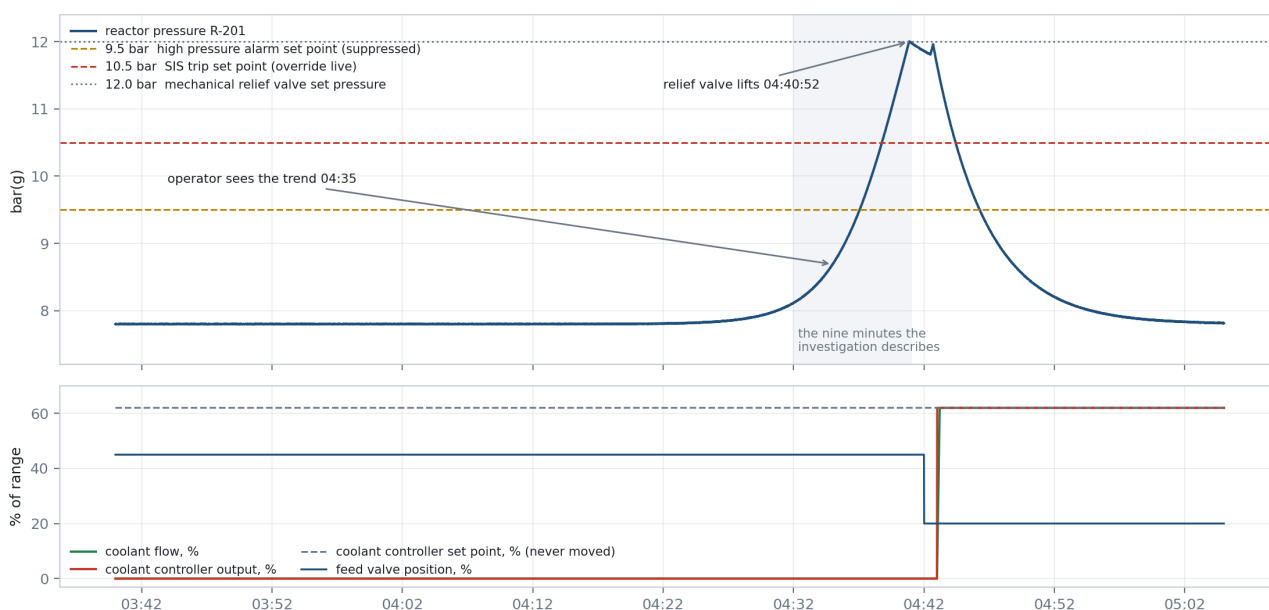


Figure 4 - The historian's own record, taken from the prototype run. Pressure rises through the alarm set point and the trip set point without either one acting. The feed valve holds position throughout.

The pressure trace is the clearest single artefact in the case. Between 04:32 and 04:41 the record shows pressure climbing from normal operating pressure to the relief valve set pressure, coolant flow at zero throughout, and the feed valve sitting at its commanded position the whole time (F1).

Read the three protections that did not act in order.

- Layer 2, the alarm. The 9.5 bar set point is crossed. The alarm is configured and would have been presented. It was suppressed at 23:58, so nobody was told.
- Layer 3, the trip. The 10.5 bar trip set point is crossed. The trip logic is intact and the final elements are healthy, but the pressure input is overridden, so the condition can never be met and the feed valve never closes. Confirmation that the trip would have worked is in the control run: with no override in place, the same code trips at 10.55 bar and shows the feed valve closed.
- Layer 1, the cooling. This was never actually running. The controller was producing zero output from 02:14; the vessel simply took time to notice.

At 04:35 the panel operator noticed the rising trend himself, on a display, with no alarm to prompt him, and began reducing feed by hand at 04:36. By 04:41 the change had not reached the valve. Six minutes of unnoticed reactor pressure is not a criticism of the operator; it is a statement that the system was relying on a human noticing something that three engineered controls had been configured to hide from him.

04:41: the last layer, the one nobody can reach

The relief valve lifted at its set pressure, discharged to the scrubber for about ninety-six seconds and reseated (F29). It was certified in the 2026 turnaround, it is spring-loaded and mechanical, and it has no electronics, no network and no credential. Nothing in the preceding four hours and forty-nine minutes could touch it.

In the prototype the same sequence produces a lift at 12.0 bar and a discharge of ninety-eight seconds. The four-second difference between the model and the case study record is a modelling artefact, not information. The point is the shape: the valve opened, the vessel relieved, the valve closed, and everything the safety report's fourth layer was supposed to do, it did.

Afterwards

The night operator opened the emergency coolant valve by hand within seconds of the relief valve reseating, and the shift engineer restored the coolant loop configuration at 04:43. The plant was shut down. The state factory inspectorate was notified. Process Safety opened its investigation the same morning, established within four hours that the alarm had not been presented and the SIS had not tripped (F30), and asked for the safety controller's event log on 6 April, at which point entries nobody could account for turned up and external investigators were engaged on 7 April.

Note the two and a half day delay between the incident and the log read, and hold on to it, because it interacts with the retention problem in Part 9.

Part 6 - Why it happened

There is a temptation with an incident of this shape to identify the attacker as the cause, describe their skill, and stop. That would miss the point and leave the site just as exposed. The attacker here did not defeat Deccan's defences. Deccan's defences, in the only configuration that mattered, did not exist yet, and had not existed since 2021.

The right framing is this: a determined adversary found a set of conditions. Any competent one would have. The conditions are the finding.

6.1 The vulnerability that mattered, stated plainly

Common-cause failure: three of the four protection layers that the safety report treats as independent became reachable from a single account on a single workstation, and nothing in the safety case was re-checked when that happened.

The safety report multiplies the risk reduction credited to four layers. Multiplication assumes independence (F18). Independence was destroyed in 2021 by a project that put the two engineering suites on one domain-joined host (F6, F20), put both controllers on one network segment behind a VLAN alone (F21), and put both systems in the hands of the same nine engineers using the same corporate accounts (F6). The assessment of whether a single actor could now affect more than one layer was never performed, then or since (F32).

Everything that follows is a consequence. The attack did not need to be sophisticated because the architecture had already done the hard part.

6.2 Why the attacker could do it: the technical weaknesses

No authentication on the safety engineering protocol (F11)

The protocol between the configuration software and the safety controller requires nothing of the caller. There is no credential, no session, no integrity protection. Whatever a client asks for, the controller considers. For a protocol that only ever runs between an engineering workstation and a controller in the same rack, in the same plant, this was a design choice somebody once made for good practical reasons. It stopped being reasonable the moment the workstation became domain-joined, because it means the security of a safety system is now determined entirely by who can get onto the host and onto the segment.

A site-wide password published in the vendor's manual (F12)

The only authorisation on the whole path is a configuration-mode password held in the vendor's documentation as a site-wide value, identical on every installation of that software version, and never changed at Deccan. The practical effect is that the credential protecting a SIL 2 safety function is public. This is not an obscure finding; it is the sort of thing that turns up in the first hour of any assessment of a system like this, which raises its own question about why it had never been assessed here.

An override with no expiry, and no visible indication (F8, F9, F10)

A safety bypass with no time limit is a bypass, not an override. Once set, this one persists until somebody deliberately clears it, and the two indications that it exists are a panel mounted on the rear wall behind the operator's normal working position (F9) and a list he has to choose to open (F17). Neither is designed to demand attention, and neither got it.

Alarm suppression that hides itself from the person it protects (F16, F17)

Suppression exists for good reasons and will always be needed. The weakness here is that it is silent: no banner on the operator's display, no reminder, no expiry, and no history of what was suppressed or when. A legitimate suppression and a hostile one leave exactly the same footprint, which is a maintenance-tooling problem long before it is a security problem.

Identity controls that stop at the plant door (F26)

Multi-factor authentication is enforced for remote access and not for interactive sign-in to workstations on site. That is a defensible corporate position in general and an indefensible one for a workstation that can reconfigure a safety function. On the night, a password alone was enough.

A help desk process that verifies identity with a public number (F27)

Employee numbers are printed on badges, badges are worn on chests, and badges are visible to anyone standing near the badge-holder, including contractor staff, visitors and anyone who has ever seen a photo. Using it as the proof of identity for a password reset is close to not verifying at all, and it is the weakest link anywhere in this estate.

A plant network nobody watches (F24)

No flow records, no OT-aware detection, no alerting on any of the eleven telemetry sources Deccan does collect. Everything in this investigation was reconstructed after the fact from passive logs; nothing would have surfaced it in real time, and as of today nothing still would.

6.3 Why nobody caught it: the governance failures

The technical weaknesses are ordinary for a plant of this vintage. The governance failures are the interesting part, because each of them is individually defensible and collectively fatal.

The change was real, and was assessed as the wrong kind of change (F19)

The 2021 project had a management of change record. It was risk assessed. The assessment covers licence compliance, vendor support and workstation performance, which are, to be fair, the things that project was for. Nobody asked Process Safety because nobody thought a workstation relocation was a process safety matter, and the process that should have forced that question classified the change as an IT one and moved on.

The safety case was re-confirmed without being re-verified (F22, F23, F15)

The safety report has been reviewed every year since 2021, each review confirming the report remains valid, none of them referencing the 2021 project. The August 2026 inspection checked the proof test records and found them in order. The proof test itself tests the safety function end to end and requires overrides to be cleared before it starts, by the engineer performing the test (F15), which means the one recurring independent check of this system cannot see a pre-existing override.

Three separate assurance activities, all performed, all documented, all passing, and none of them capable of detecting the condition that mattered. That is the pattern to sit with. It is not a story about people not doing their jobs. It is a story about assurance activities that measure the wrong thing.

The question was never asked (F32)

Deccan has no record, at any time, of any assessment of whether a single person or a single compromised account could affect more than one protection layer. That is the whole incident in one sentence. It is not a missing control or a missing tool; it is a missing question, and the reason the other governance findings exist is that nobody had a reason to ask it.

6.4 Why it took until 6 April to find

Three things slowed the discovery, and each of them is fixable.

1. The incident had no cyber signature, so it did not look like a cyber incident. The investigation that began on 3 April was a process safety investigation, and it was right: a demand reached the final protection layer and the third layer did not act (F30).
2. The safety controller's log only became interesting on the sixth of April, when somebody thought to read it, and by then the ring buffer had been recycling for three days.
3. Once read, the log gave up the override quickly and then stopped, because the answers to the two questions that mattered, who and since when, live in log sources that either do not exist (F24) or have already overwritten them (F31).

Part 7 - The kill chain

Eight stages, from target selection to aftermath. Each stage gives the attacker's step in short form, the tooling that would be used, and the evidence from the investigation that supports it. Where a stage rests on inference rather than evidence, it says so.

Two conventions. 'Command or tool' describes what an attacker would reach for; where the case study contains no evidence of tooling, the field says so rather than inventing one. Technique identifiers are indicative mappings to MITRE ATT&CK for ICS and are given as orientation, not as a claim about a specific tool.

Stage 1 - Target selection and reconnaissance

Title	Target selection and reconnaissance
Command or tool	External reconnaissance only: vendor documentation for the safety system, published material about the site, and general internet scanning as background. No evidence of network enumeration against Deccan exists, because no flow records are kept on the plant segment (F24).
Details	Somebody chose this site, this plant and this class of system. Nothing in the case study shows how, and the prototype deliberately does not speculate. What can be said is what made the target attractive: a domain-joined engineering workstation that engineers both the control system and the safety system (F6), a vendor engineering protocol with no authentication (F11), and a documented site-wide configuration password (F12). The last of those is available to anyone who can read an installation guide, which means target selection for this specific attack needed no access to Deccan at all.
Evidence	F6, F11, F12, F20, F21. Inference: the reconnaissance itself is unrecoverable, and F24 is why.

Stage 2 - Access acquisition through the service desk

Title	Credential acquisition through a password reset verified by a public identifier
Command or tool	A telephone call to the service desk. No exploit, no tooling. Caller identifies as a Control and Instrumentation engineer who cannot sign in to ENG-DCS-01 and quotes an employee number.
Details	On 11 December 2026 the service desk recorded a ticket in which a Control and Instrumentation engineer could not sign in to ENG-DCS-01 and had his password reset, with identity verified by employee number, which is printed on the site identity badge (F27). That engineer is one of the four accounts that later appear in the night-access pattern (F5). No call-out records, no attendance records and no system log connect this reset to what followed, so this stage is presented as a candidate, not as an established fact. It is included because the process as designed could not have stopped an impersonation attempt, and because the timing is eleven days before the anomalous access begins.
Evidence	F27 (primary), F26 (why a password was sufficient), F5 (temporal proximity). Unproven.

Stage 3 - Establish sustained, low-noise access, and rehearse

Title	Repeated interactive sign-ins at night under four borrowed engineer accounts, with two rehearsals of the override mechanism
Command or tool	Interactive sign-in to ENG-DCS-01 at the console, using valid corporate credentials. From the network's point of view this is an engineer logging in. No tooling is required and none was needed.

Details	The domain log records 27 interactive sign-ins to ENG-DCS-01 between 6 January and 3 April, using four engineers' accounts, of which 21 fall between 01:00 and 05:00 against a day-shift roster with telephone call-outs, and only two have a matching call-out record (F5). Two override events in the safety controller's log have no matching proof test record, on 11 January and 7 March, both on the same pressure input that was overridden on the night of the incident (F10), both inside the anomalous access window. The natural reading is reconnaissance and rehearsal, giving the attacker confidence in the mechanism and in the fact that nothing watches it. Endpoint detection saw none of it and raised nothing across a full year (F7), which is not a failure of the tool: logging in with valid credentials is not a detection.
Evidence	F5, F10, F7 (absence of detection), F31 (which limits how far back this can be seen).

Stage 4 - Neutralise the safety instrumented system

Title	Maintenance override set on the reactor high pressure input, with no expiry
Command or tool	The vendor's safety configuration software, or any client that can speak the engineering protocol. VEL/1 in the prototype. The configuration-mode password is read from the vendor's installation guide.
Details	At 23:52 on 2 April an override was set on PIT-104 and never cleared (F8). The controller accepted it with the key switch in RUN, because a logic download is refused in RUN but an override is not (F13), and it recorded no expiry against it because there is no expiry to record (F10). The practical effect is that the SIL 2 trip became unreachable: the pressure input reports healthy whatever the vessel does. The logic itself was never touched, which the log confirms (F14) and which matters enormously to everything that follows, because it is why the safety system looked untampered with afterwards. The prototype reproduces this write against a live mock controller; the transcript is in Appendix B.
Evidence	F8, F11, F12, F13, F14, F10.

Stage 5 - Remove the alarm from the operator

Title	Reactor high pressure alarm suppressed from the engineering workstation
Command or tool	The control system engineering interface on ENG-DCS-01, using the same corporate account already in use on that host.
Details	At 23:58 the high pressure alarm was suppressed from ENG-DCS-01 (F16). The suppression is recorded in the control system journal because the feature writes a journal entry, and the suppression list itself keeps current state only with no history (F16). The operator's default view does not show suppressed alarms; he must open a list to see them, and he did not (F17). The stage matters because it removes the human layer that the safety report credits with a risk reduction factor, and it does so using a legitimate maintenance feature that exists for good reasons.
Evidence	F16, F17, F9 (the same class of visibility problem on the safety side).

Stage 6 - Stop the cooling, and start the clock

Title	Coolant flow controller reconfigured so its output tracks zero regardless of set point
Command or tool	The control system engineering interface on ENG-DCS-01. In the prototype, loop.configure against the DCS controller.
Details	At 02:09 an interactive sign-in to ENG-DCS-01 occurred under the corporate account of an engineer who was not at the site and not working (F4), and at 02:14 the coolant flow controller was reconfigured from that workstation under that account (F3). The write set the controller gain to zero and left the bias at zero, which makes the output zero for every set point. The set point was never moved, and the journal records no operator action on the controller, while the historian shows the output at zero against an unchanged set point (F2). Everything about the plant's normal operating picture stayed intact. This is the step that creates the hazard, and it is the step that the historian records most clearly.

Evidence	F3, F2, F1, F4, F26 (why a password was enough).
----------	--

Stage 7 - Let the physics do the rest

Title	Wait through the thermal take-off, with every automatic protection blinded
Command or tool	None. Nothing further was required of the attacker, and nothing further appears in any log.
Details	Two hours and eighteen minutes after cooling stopped, the reactor began to heat. Between 04:32 and 04:41 the pressure climbed from normal operating pressure to the relief valve set pressure, with coolant flow already at zero and the feed valve holding its commanded position throughout (F1). The 9.5 bar alarm condition was met and not presented, because it had been suppressed. The 10.5 bar trip condition was met and the SIS did not act, because its pressure input was overridden; the control run in the prototype confirms the same logic trips at 10.55 bar and closes the feed valve when no override is present. The operator noticed the trend by eye, with no alarm to prompt him, and started reducing feed at 04:36; the change had not reached the valve when the relief valve lifted at 04:41. The mechanical relief valve is the only layer that performed, and the only one nothing in the chain could reach (F29).
Evidence	F1, F8, F16, F18, F29, F30.

Stage 8 - Leave no trace, and blend into the noise

Title	Exit without detection, leaving an event record that reads as routine and an evidence trail that expires on its own
Command or tool	None. The evasion in this incident is structural rather than active. Nothing was deleted, because nothing needed to be.
Details	No malware was present and no unexpected executable was found, so endpoint detection had nothing to report and reported nothing across a full year of alert history (F7). No logic download occurred, so the safety system's logic matched the proof tested version and any hunt for tampering would come up empty (F14). The three writes were made with the vendor's own software, so they look like engineering. The firewall saw only permitted engineering traffic from the engineering workstation, which is what it expects (F25). The plant segment has no flow records at all, so no network evidence exists to contradict any of this (F24). Finally, the safety controller's event log keeps 5,000 events and overwrites, so the record of the override and of the January rehearsals was being recycled by the controller's own housekeeping while the plant was still shut down (F31). This is the stage that explains why the incident was found by process safety reasoning four hours after the fact and a cyber reconstruction five days after it, rather than by any detection.
Evidence	F7, F14, F24, F25, F31, F28 (the decoy).

The chain in one picture

2021	convergence project, assessed as an IT change, Process Safety not involved SIS + DCS engineering on one host, one domain, one account, one VLAN independence assumption in the safety case never re-verified		
Dec 26	password reset verified by a badge number	[candidate, unproven]	
Jan-Apr 27	27 sign-ins to ENG-DCS-01, four accounts, 21 at night, 2 with call-outs 3 override events with no proof test record	[rehearsal, probable]	
2 Apr 23:52	override set on the SIS pressure input	layer 3 blinded	
23:58	high pressure alarm suppressed	layer 2 hidden	
3 Apr 02:09	sign-in under an account whose owner is elsewhere		
02:14	coolant controller reconfigured, sp untouched	layer 1 stopped	
3 Apr 04:32 - 04:41	pressure climbs, nothing alarms, nothing trips		
04:41	relief valve lifts, discharges, reseats	layer 4, unreachable (F29)	

6 Apr safety controller log read; override found; the rest of the trail is gone

Part 8 - Reproducing it on the prototype

This part is the proof. Four runs of the mock, what each one produced, and what each one settles. The raw output is in Appendix B and in the lab/out folder that ships with this report.

Run 1 - Baseline and control

First, a short healthy baseline so the historian has normal operating data to compare against. Then something more useful: a control run. The same safety controller code, the same trip set point, no override, nothing suppressed, and a synthetic pressure ramp.

```
--- control test: SIS trip with no override in place ---
pressure  9.90 bar   trip=False {'FV-102': 'OPEN', 'XV-118': 'CLOSED'}
pressure 10.25 bar   trip=False {'FV-102': 'OPEN', 'XV-118': 'CLOSED'}
pressure 10.60 bar   trip=True  {'FV-102': 'CLOSED', 'XV-118': 'OPEN'}
pressure 10.95 bar   trip=True  {'FV-102': 'CLOSED', 'XV-118': 'OPEN'}
```

The trip works. It works at the set point, it closes the feed valve, it opens the emergency coolant valve, exactly as designed and exactly as proof tested. This run exists so that nobody can read the rest of this report and conclude the safety system was faulty. It was not faulty. It was blinded.

Run 2 - The incident

The night of 2-3 April, in the order the case study gives it. Three writes, then the physical consequence. The transcript, abridged:

```
[2027-04-02 23:52:00] configuration mode on the SIS: {'ok': True, 'config_mode': True}
[2027-04-02 23:52:00] override SET on PIT-104 while the key switch is in RUN
                        - accepted, no expiry, no time limit
[2027-04-02 23:58:00] high pressure alarm R-201-HP-ALM suppressed from ENG-DCS-01
[2027-04-03 02:09:00] interactive sign-in to ENG-DCS-01 as a.rathod (holder is off site)
[2027-04-03 02:14:00] coolant controller FIC-101 reconfigured from ENG-DCS-01:
                        {'gain': '1.0 -> 0.0', 'bias': '0.0 -> 0.0'}
                        - output now tracks 0 regardless of set point
[2027-04-03 04:35:00] the operator notices the rising trend on a display at 8.69 bar
                        - nothing alarmed, he was looking at the trend himself
[2027-04-03 04:37:04] layer 2 demand: pressure 9.50 bar crossed the 9.5 alarm set point.
                        Presented to the operator: False (suppressed=True)
[2027-04-03 04:40:52] layer 4: the PRV lifts at 12.00 bar and discharges to the scrubber
[2027-04-03 04:42:24] the PRV reseats after 92 seconds (the case study records 96 s, F29)
[2027-04-03 04:42:36] the operator opens the emergency coolant valve XV-118 by hand.
                        The valve the SIS would have opened on its own at 10.5 bar is
                        opened by a person, seconds after the relief valve had done the job.
```

The pressure trace that comes out of this run is Figure 4. Two features of it are worth checking against the case study by eye, because they are the two the investigation leaned on hardest: the feed valve stays at 45 per cent for the entire rise (F1), and the coolant controller output is at zero against an unchanged set point for the whole night (F2).

Run 3 - The investigation, performed against the artefacts

This run does not replay the attack. It reads what the attack left behind, using the retention rules the case study gives. Five questions, and the answers the logs actually support:

Question	Answer from the logs	Findings reproduced
Why did layer 3 not act?	One override live on PIT-104 at read time, set 23:52, expiry not configured; zero logic downloads in the retained window; logic version identical to the proof tested version	F8, F10, F13, F14

Question	Answer from the logs	Findings reproduced
Why did no alarm reach the operator?	One suppression event journalled at 23:58; suppression list holds current state only; list not displayed by default; alarm event recorded as raised and not presented	F16, F17
What changed the cooling?	Two configuration changes on FIC-101 (02:14 and the 04:43 restoration), zero operator actions on it, output range 0.0 to 0.0 through the rise window against a set point fixed at 62.0, feed valve fixed at 45.0, pressure 8.11 to 11.92 bar, relief valve lifted once for 98 seconds	F1, F2, F3, F29
Who was on the workstation?	27 sign-ins to ENG-DCS-01, 21 between 01:00 and 05:00, four accounts, two call-outs on record, 19 without; MFA not used on interactive sign-in; zero endpoint alerts in 365 days; firewall plan full of permitted engineering traffic; one service desk ticket verified by badge number	F4, F5, F7, F25, F26, F27
What cannot be recovered?	SIS ring holds 5,000 events covering 86.4 days back to 9 January 2027; no plant flow records and no capability to collect them; 220,000 refused connections at the internet edge from 9,400 sources, unrelated	F24, F28, F31

Table 8.1 - What the reconstruction found, run against the artefacts from run 2

Every count in that table came out of the mock's own logs rather than out of the case study's text, and they land on the case study's numbers: 27 sign-ins with 21 out of hours, 19 without a call-out, 14 override events with only 11 clears, 0 endpoint alerts in 365 days, and a ring log that reaches back to early January and no further.

Run 4 - Replay with each mitigation switched on

The last run reruns the same night with the fixes turned on, one at a time. This is the part that decides what to do first: it shows which control actually breaks the chain and which one merely shortens it.

Control	Effect on the incident	Verdict
Lock-out on repeated configuration password failures	Slows a password-guessing attacker. Does nothing against someone who read the password out of the vendor guide, which is what happened here	Marginal. Do it anyway, but not for this
Hard expiry on maintenance overrides	At the moment of demand the override is gone, the trip fires, the feed valve closes. In the replay the SIS trips and the feed valve is CLOSED	Breaks the chain
Alarm suppression requires a permit, and is displayed	Suppression refused with no covering permit; the operator is told at 9.5 bar instead of finding the trend by eye	Breaks the chain
Configuration writes refused outside an approved change window	The 02:14 write is refused and journalled as a refusal. Layer 1 stays up	Breaks the chain
Safety engineering moved back to a dedicated, non-domain host	The corporate account used on the night has no path to the logic solver at all. Nothing else in the chain matters	Removes the whole class

Table 8.2 - What each candidate control does to the chain

Read the table down the left column and the ranking in Part 11 writes itself. The two controls that sound most like security, password lock-out and network separation, are the two that would not have stopped this. The controls that stop it are the unglamorous engineering ones: time limits on bypasses, visibility for suppressed alarms, and a change window.

Running it yourself

Everything above is reproducible on one machine in under a minute, with no third-party packages and no network access beyond loopback. The dashboard has a play button for the scripted night and three buttons to fire the three writes by hand. Watching the four protection layer lamps go out one at a time, in the order the incident made them go out, is the fastest way to see the shape of this.

Part 9 - What we cannot know, and why

An investigation that does not say where its knowledge stops is not an investigation. Three limits, and one that may be permanent.

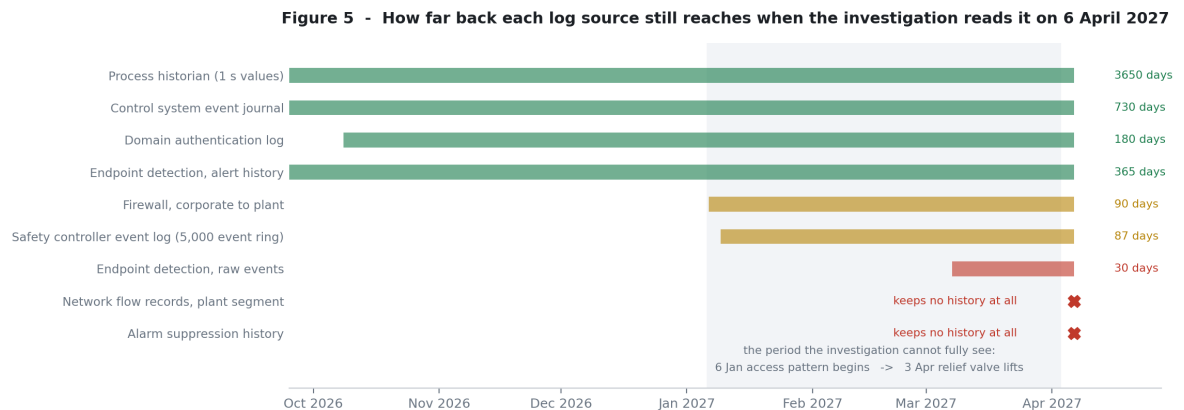


Figure 5 - Retention against the timeline. The access pattern starts in January and the incident is in April; two of the sources that would explain the earlier period have already expired by the time anyone looks.

The start of the campaign is unrecoverable

The safety controller's event log holds 5,000 events and overwrites. When it was read on 6 April it reached back to 9 January. The event that pushed the oldest entries out was the controller's own periodic housekeeping, which nobody has any reason to stop and no way to slow down. Anything before 9 January is gone.

The prototype reproduces this, and it reproduces the same conclusion: at the modelled event rate the ring buys about eighty-seven days, which lands the oldest retained entry in the first week of January with the read on 6 April. The practical consequence is that we cannot say whether the January rehearsals were the first ones, and we cannot say whether the overnight access pattern started in November, in September, or last year. This question will never be answerable with the current controller.

The plant network is unobservable

There are no flow records on the plant segment and no capability to collect them (F24). So we cannot establish whether the safety engineering protocol was ever addressed from a host other than ENG-DCS-01, whether any other device on that segment was involved, or what else may have happened on that network in the last three months. The lab can only model what the case study allows, and the case study allows exactly this: the connection from ENG-DCS-01 to the safety controller, and nothing around it.

Suppression history does not exist

The suppression list keeps current state only (F16). The single suppression event on the night survives only because the control system journal happens to record the suppression action. Whether suppression had been used before, rehearsed, or tried and abandoned elsewhere is not knowable from the data. The safety side has an equivalent limit: the override history that exists is whatever the ring log still holds.

Attribution is open, and this report does not close it

F4 proves that one account was used by somebody other than its owner. Nothing in the findings establishes whether the other three accounts in F5 were used the same way, or whether one or more account holders were personally involved. The technical evidence can describe the access pattern with

some confidence and cannot name a person. That is a personnel and law enforcement question, and it should be run in parallel rather than waiting on the engineering remediation.

One caution for whoever takes that work on. The four-account pattern is more consistent with an external actor holding multiple credentials than with a single insider at a panel, and it would be easy to write that down as a finding. It is not a finding. It is a direction.

Part 10 - What it cost, and what it put at risk

This time

Eleven hours of interrupted throughput, a full plant shutdown pending investigation, and one relief valve discharge to the scrubber. No release to atmosphere, no injury, no damage to equipment. By any ordinary measure, a near miss.

The risk that was actually carried

The site safety report's own hazard basis is a loss of containment of a toxic and flammable inventory, with a residential settlement 1.8 kilometres from the boundary. On the night, three of the four layers credited in that report were out of action before the hazard existed, and the fourth was a spring. This is as close to the site's credible worst case as an operating plant can get while still being a near miss.

There is a second risk that is less obvious and harder to put in a report. Nothing in this incident depended on the target being Deccan. The mechanism used here, a domain-joined engineering workstation that reaches both a control system and a safety system, behind a protocol with no authentication and a documented shared password, is not unique to this site. The other two Deccan sites sit under the same corporate IT function, with the same 1,100 accounts and the same password and MFA policies (F26). Nothing in this investigation confirms or excludes the same convergence there. That check should not wait.

The regulatory position

The site safety report's quantitative risk assessment is invalidated, and not only for this event. The risk reduction figures submitted to and accepted by the state factory inspectorate rested on an independence assumption that stopped being true in 2021, in a report that continued to be reviewed and re-confirmed as valid every year since (F22). The August 2026 inspection accepted the SIS as independently proof tested on the basis of records that could not have surfaced this (F23, F15).

That raises a question the site cannot answer on its own and should not try to. If an inspection regime can find a plant compliant six months before one account removes three of its four protection layers, the gap is not only in Deccan's assurance. It is worth putting that question to the regulator directly, in writing, alongside the notification that has already been made.

The assurance gap in one line

Three independent assurance activities looked at this safety system between 2021 and 2027: an annual report review, a six-monthly proof test, and a regulatory inspection. All three were performed, all three passed, and all three were structurally incapable of detecting the condition that made this incident possible. Fixing that is the most valuable thing Deccan can take from this event, and it is cheaper than fixing anything mechanical.

Part 11 - What to do, in order

Ranked by how much each item shortens the chain, with the finding it closes and the effort it takes. The first three are urgent. The rest are important and can be planned.

#	Action	Closes	Why here in the list
1	Separate SIS engineering from DCS engineering again. A dedicated, non-domain-joined workstation for safety configuration, on a controlled path, is the single decision that removes this entire class of attack.	RC1, F6, F20, F21	It reverses the one architectural choice that made every other step possible. Nothing else on this list is as load-bearing.
2	Re-run the safety report's independence analysis against the as-built architecture, and route every future change that touches either system through Process Safety, regardless of how the change is categorised.	RC2, RC3, F18, F19, F22	The safety case has been wrong since 2021 and is currently wrong. It is also the fix that stops the next convergence project being approved as IT housekeeping.
3	Put a hard time limit on maintenance overrides with automatic expiry and re-authorisation, and give active overrides a prominent, default-visible indication in the operator's primary field of view.	RC6, F8, F9, F10	Directly breaks the chain at layer 3, and it is a configuration change rather than a project.
4	Redesign the proof test so override state is verified as a logged precondition, not silently cleared by the engineer performing the test.	RC7, F15	Fixes the one recurring independent check that exists, at almost no cost. Without this, a manipulated override can hide behind a passing test indefinitely.
5	Make alarm suppression require a permit, expire it automatically, and show it on the operator's primary display.	RC6, F16, F17	Breaks the chain at layer 2 and removes the mechanism that hid the condition from the person best placed to act.
6	Change the vendor configuration password from the published default and manage it as a secret. Push the vendor for per-engineer authentication on the safety engineering protocol.	RC4, F11, F12	Cheap, immediate, and it closes the specific string that made this trivial. It is a speed bump rather than a wall, because the protocol still has no authentication.
7	Enforce MFA on interactive sign-in to any workstation that can reach safety instrumented system configuration, and stop using badge employee numbers for identity proofing on credential resets.	RC5, F26, F27	Both controls were written for a corporate estate and applied without regard to what one particular workstation can do. The reset process change can be made this week.
8	Build minimal OT monitoring on the plant segment: alerting on safety controller mode changes, override sets and clears, and alarm suppressions, routed to Process Safety as well as IT.	RC8, F24	Turns a five-day post-hoc discovery into a five-minute notification. It does not stop the attack; it stops the next one being discovered by accident.
9	Extend the safety controller's event log or export it off-device, so the next investigation is not limited by a 5,000 event buffer.	F31	Low cost, high value, and it is the only way future attribution questions can be answered at all.
10	Answer F32 in writing, across all three sites, and repeat the exercise for any other system where one host or one account can reach more than one protection layer.	RC9, F32	It is the question nobody asked. Answering it once, properly, is what stops this recurring somewhere else on the estate.
11	Treat this as a potential deliberate act rather than solely a process safety failure, and pursue attribution through personnel, legal and law enforcement channels in parallel with the engineering work.	F4, F5, F10, F27	The engineering fixes prevent recurrence. They do not answer who did it, and that answer affects how the site should think about its exposure.

Table 11.1 - Actions, ranked

Two things not to do

First, do not spend the next month on the January scanning (F28). It is noise, it has been characterised as noise, and every hour spent on it is an hour not spent on item 1.

Second, do not take comfort from the clean endpoint (F7) or the untouched safety logic (F14). Both are true and both are beside the point. The lesson this incident teaches, if it teaches only one, is that the absence of malware is not the absence of an attack, and that an intact safety system can still be an inoperable one.

Appendix A - The finding register in full

All thirty-two findings as the investigation established them, numbered as in the case study, with the report's category for each. The commentary behind each category is in Part 4.

ID	Category	Finding
F1	[CORE]	Historian shows reactor pressure rising from normal operating pressure to relief valve set pressure between 04:32 and 04:41, coolant flow reducing to zero over the same period and the feed valve remaining at its commanded position throughout.
F2	[CORE]	Coolant flow controller output fell to zero while its set point was unchanged, and the control system event journal records no operator action on that controller.
F3	[CORE]	The control system event journal records a configuration change to the coolant flow controller at 02:14 on 3 April, made from ENG-DCS-01 under the corporate domain account of a Control and Instrumentation engineer.
F4	[CORE]	The engineer named in F3 was not at the site and was not working; his corporate account shows an interactive sign-in to ENG-DCS-01 at 02:09 on 3 April.
F5	[SUSPICIOUS]	The domain authentication log records 27 interactive sign-ins to ENG-DCS-01 between 6 January and 3 April 2027 using the accounts of four different Control and Instrumentation engineers, of which 21 occurred between 01:00 and 05:00; call-out records exist for two.
F6	[ENABLER]	ENG-DCS-01 is joined to the corporate Windows domain, engineers sign in with corporate accounts, and the workstation hosts both the control system engineering software and the safety configuration software.
F7	[MASK]	Corporate endpoint detection covers ENG-DCS-01 and retains 30 days; it raised no alert on that asset at any point in a 365 day alert history, and the investigation found no malware and no unexpected executable.
F8	[CORE]	The safety controller's event log records a maintenance override set on the reactor high pressure input at 23:52 on 2 April; the override was not cleared before the event on 3 April.
F9	[ENABLER]	The active override is displayed on a dedicated panel on the rear wall of the control room, behind the operator's normal working position; the night shift operator recorded in his handover that he did not observe the panel.
F10	[ENABLER]	There is no time limit on a maintenance override and no automatic expiry; the controller log records 14 override events in the retained window, of which 11 correspond to proof test records and 3 do not.
F11	[ENABLER]	The safety configuration software communicates with the safety controller over the vendor's proprietary engineering protocol, which carries no authentication; authorisation is enforced by the software, which requires a password to enter configuration mode.
F12	[ENABLER]	The configuration mode password is a property of the software installation, held in the vendor's documentation as a site-wide value, identical on every installation of that software version. Deccan has not changed it.
F13	[ENABLER]	The safety controller's key switch has RUN and PROGRAM positions; a logic download is refused in RUN, and an override may be set in RUN.
F14	[MASK]	The safety controller's event log records no logic download in the retained window, and the logic on the controller on 8 April matches the version recorded in the most recent proof test record.
F15	[GOV]	The most recent proof test, on 14 February 2027, is recorded as passed; the procedure tests the function end to end but does not test whether an override is active, because the procedure requires overrides to be cleared before the test begins and the engineer performing the test clears them.
F16	[CORE]	The control system event journal records the reactor high pressure alarm suppressed at 23:58 on 2 April from ENG-DCS-01; the alarm suppression list holds current state only and carries no history.
F17	[ENABLER]	Suppressed alarms appear on a list the operator may open; the list is not displayed by default and the operator on shift did not open it.
F18	[GOV]	The site safety report identifies four independent protection layers, credits each with a risk reduction factor, multiplies those factors, and states the layers are independent.

ID	Category	Finding
F19	[GOV]	The 2021 convergence project's management of change record exists and is categorised as an information technology change; its risk assessment addresses licence compliance, vendor support and workstation performance; it does not reference the site safety report and Process Safety is not recorded as a reviewer or approver.
F20	[ENABLER]	Before 2021 the safety instrumented system was engineered from a dedicated workstation in a locked cabinet in the rack room and the control system from a separate station in the control room; since 2021 both are engineered from ENG-DCS-01.
F21	[ENABLER]	Since 2021 the safety controller and the control system controllers have been on the same physical network segment, separated by VLAN.
F22	[GOV]	The site safety report has been reviewed annually since 2021, each review recorded as confirming the report remains valid, and no review references the 2021 convergence project.
F23	[MASK]	The state factory inspectorate's most recent inspection, in August 2026, examined the safety report and the proof test records and recorded the safety instrumented system as compliant and independently proof tested.
F24	[GAP]	Network flow records for the plant segment are not collected and no capability exists to collect them.
F25	[NOISE]	The corporate-to-plant firewall log retains 90 days and records permitted connections from ENG-DCS-01 to the plant segment throughout the period, which is expected behaviour for an engineering workstation.
F26	[ENABLER]	The corporate Windows domain contains 1,100 accounts across three sites; passwords are twelve characters and change every 180 days; multi-factor authentication is enforced for remote access and is not enforced for interactive sign-in to domain-joined workstations on site.
F27	[SUSPICIOUS]	A service desk ticket dated 11 December 2026 records a Control and Instrumentation engineer unable to sign in to ENG-DCS-01 with his password reset by the service desk, the caller's identity verified by employee number, which is printed on the site identity badge.
F28	[NOISE]	Between 8 and 12 January 2027 the corporate firewall recorded 220,000 refused connection attempts against Deccan's internet facing addresses from 9,400 source addresses; all were refused and volumes of this kind are routine.
F29	[CORE]	The pressure relief valve is a spring-loaded mechanical device with no electronics, sized to pass the full reaction rate, certified in the 2026 turnaround; it lifted at its set pressure and reseated correctly.
F30	[CORE]	Process Safety's investigation on 3 April established within four hours that no high pressure alarm had been presented and that the safety instrumented system had not tripped, and requested the safety controller event log on 6 April.
F31	[GAP]	The safety controller's event log holds 5,000 events and is overwritten; when it was read on 6 April it retained events back to 9 January 2027.
F32	[GOV]	Deccan has no record of any assessment, at any time, of whether a single person or a single compromised account could affect more than one protection layer.

Table A.1 - Finding register

Appendix B - Lab artefacts

Every artefact referenced in this report is in the lab/out folder that ships with it, and every one of them was produced by running the mock. Nothing in the report quotes a number that is not in one of these files.

File	What it is	What it establishes
incident_historian.csv	The historian's own record of the night, one second resolution	F1 and F2: pressure rising 8.11 to 11.92 bar, coolant output zero against a 62 per cent set point, feed valve fixed at 45 per cent
incident_sis_log.txt	The safety controller's event log as read on 6 April	F8, F10, F13, F14, F31: the override, the absent clear, no logic download, and the ring's oldest retained entry
incident_dcs_journal.txt	The control system event journal	F3 and F16: the 02:14 configuration write under the engineer's account, and the 23:58 suppression
incident_ad_auth_log.txt	The domain authentication log	F4, F5 and F26: the 02:09 sign-in, the night-sign-in pattern, and MFA not used
incident_events.txt	The run's own transcript, timestamped	The order of events, which is the kill chain
investigation_results.json	The structured output of the four reconstruction steps	The counts quoted in Table 8.1
investigation_findings.txt	The same results in readable form	The same
replay_mitigations.txt	What each candidate control does to the chain	The ranking in Part 11
baseline_control_test.txt	The control run: no override, nothing suppressed	That the trip works at 10.55 bar and closes the feed valve, which is why this incident is about blinding rather than breakage
inject_transcript.txt	The mock attack tool's session against the live controller	Appendix B, below: the three writes, with the controller's responses, including 'auth_required': false

Table B.1 - Artefact index

Abridged attack-tool transcript

Captured by running the mock engineering tool against the live mock controller. Abridged for length; the full transcript is in evidence/inject_transcript.txt.

```
STAGE 2: LAYER 3 - put a maintenance override on the pressure input
target      : SafeGuard SIS    logic R201-SIS-L4.2 (proof tested 14 Feb 2027)
key switch  : RUN
password    : 'VTA-SAFE-2019'
              read from the vendor install guide, section 4.3;
              'a site wide value, identical on all installations'
auth        : {'ok': True, 'config_mode': True}
override    : {"tag": "PIT-104", "set_at": "2027-04-02 22:00:00",
              "set_by": "ENG-DCS-01", "reason": "instrument drift check",
              "expires": null}
              expires: null    <- there is no time limit (F10)
              accepted while the key switch is in RUN (F13)

STAGE 3: LAYER 2 - take the high pressure alarm off the operator
alarm       : R-201-HP-ALM suppressed -> True
              the operator is not told. the suppression list exists,
              it is simply not drawn on his default view (F17).

STAGE 4: LAYER 1 - break the cooling without touching the set point
writing     : gain 1.0 -> 0.0
              the output now tracks sp*gain+bias = 0 for every set point.
```

```
STAGE 5: CHECK - the state of the plant as the attacker leaves it
safety overrides live      : [{"tag": "PIT-104", ... "expires": null}]
suppressed alarms         : [{"tag": "R-201-HP-ALM", "since": ...}]
suppressed list on screen? : False
coolant controller set point : 62.0
coolant controller gain     : 0.0
coolant controller output   : 0.0    <- was 62.0 an hour ago

three protection layers are now out of the way and nothing has been broken.
no malware, no exploit, no unusual process. three writes.
```

Appendix C - Re-running the analysis

```
cd lab

# 1. the whole replay: baseline, control test, the incident, the investigation,
#    and the mitigation replay. Writes everything into lab/out/.
python3 -c "from plantlab import flows; flows.run_all()"

# 2. the plant, with a dashboard on port 8099 that plays the night back
python3 plantlab/serve.py

# 3. what the attacker sees and does, as a transcript
python3 vel_inject.py recon
python3 vel_inject.py inject

# 4. redraw every figure in this report from the current artefacts
python3 make_diagrams.py
```

The mock binds to loopback only and is written for loopback only. It is a teaching artefact with deliberate vulnerabilities in it, including a hard-coded password and a protocol with no authentication. Do not expose it to a network you care about.

Appendix D - Basis, limits and provenance

The analysis in this report is built on the incident case study and the investigation findings supplied for it. Everything technical that is claimed about the incident is traceable to one of the thirty-two findings, and every number quoted from the prototype is reproducible from the code and the artefacts that ship with it.

Four things a reader should hold in mind.

- The prototype is a model, not a replica. It reproduces the behaviour the case study describes, in the order the case study gives it, using shapes rather than kinetics. It is for understanding the chain, not for engineering decisions.
- Where the prototype and the case study differ in detail, the case study is the record and the prototype is the illustration. The only meaningful numeric difference in the report is the relief valve discharge time, 98 seconds in the model against 96 seconds in the record.
- Stage 1 and Stage 2 of the kill chain are inferences, labelled as such. They are included because they are the most probable reading of the available evidence and because excluding them would leave a gap where the attacker must be.
- Attribution is not addressed. The technical findings establish how this happened and cannot establish who did it, and the report deliberately stops at that line.

The one thing worth carrying away from this document is not the attack. It is the question in F32, and the fact that nobody at the site had ever been asked to answer it.